

SMART CONTRACT SECURITY AUDIT - CROWDFUNDING

One-Page Visual Audit Report

Purpose: ETH crowdfunding pool with contributions, owner withdrawal and user refunds after a deadline.

Risk	Severity	SWC	OWASP
Owner can withdraw all ETH without checking goal/deadline	Critical	SWC-105	SC02 Business Logic
refund() sends funds without clearing contributions first; repeated refund/reentrancy risk	Critical	SWC-107	SC08 Reentrancy
Refunds may fail after owner withdrawal despite recorded contributions	High	SWC-132	SC02 Financial Risks
contribute() accepts funds after deadline and without goal-state rules	Medium	N/A	SC02 Business Logic

Root Cause: Funds accounting is not tied to campaign state. Contributions remain recorded while ETH can be removed or refunded without state synchronization.

Business Logic Findings: Owner can drain campaign funds, contributors can be blocked from refunds, and refund state can be reused because contribution balances are not reset.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.95 | Total_findings: 4
Critical: 2 | High: 1 | Medium: 1 | Low: 0
Precision_estimate: 0.93 | Coverage_estimate: 1.00 | Risk_score: 90/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - ELECTIONCHAIN

One-Page Visual Audit Report

Purpose: Simple voter registration and candidate vote counting contract.

Risk	Severity	SWC	OWASP
registerVoter() is unrestricted; anyone can register any address	High	SWC-105	SC01 Access Control
reRegister() allows repeat voting by re-enabling voters	High	SWC-105	SC02 Business Logic
No election admin/phase control for registration and voting windows	Medium	N/A	SC02 Business Logic
Constructor accepts zero candidates, making voting impossible	Low	N/A	SC05 Input Validation

Root Cause: Registration authority and election lifecycle are missing; voter eligibility is controlled by public functions.

Business Logic Findings: A malicious user can register or re-register accounts and distort election integrity. The contract does not enforce a final voting period or trusted registrar.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.94 | Total_findings: 4
Critical: 0 | High: 2 | Medium: 1 | Low: 1
Precision_estimate: 0.92 | Coverage_estimate: 1.00 | Risk_score: 72/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - GOVDAOCORE

One-Page Visual Audit Report

Purpose: Open DAO membership list with a compute function and ETH receiver.

Risk	Severity	SWC	OWASP
join() allows unlimited duplicate/Sybil membership entries	High	N/A	SC02 Business Logic
compute() has $O(n^2)$ loops and can become unusable through gas DoS	High	SWC-128	SC02 Gas/DoS
ETH can be received but no withdrawal/accounting mechanism exists	Medium	SWC-132	SC02 Financial Risks
No membership validation or cap on members array growth	Medium	N/A	SC05 Input Validation

Root Cause: Unbounded state growth and no uniqueness checks make membership and computation economically manipulable.

Business Logic Findings: Attackers can bloat the members array cheaply, breaking compute() and degrading governance reliability. Any received ETH may be permanently stuck.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.93 | Total_findings: 4

Critical: 0 | High: 2 | Medium: 2 | Low: 0

Precision_estimate: 0.91 | Coverage_estimate: 1.00 | Risk_score: 76/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - HIDENTREASURY

One-Page Visual Audit Report

Purpose: ETH custody contract with deposits, withdrawals and owner-controlled treasury transfers.

Risk	Severity	SWC	OWASP
Owner can drain all user funds via transferToTreasury()	Critical	SWC-105	SC01 Access Control
balances mapping not synchronized with treasury withdrawals	High	SWC-105	SC02 Financial Risks
Users may be unable to withdraw despite positive balances	High	SWC-132	SC02 Financial Risks
changeOwner() accepts zero address ownership	Low	N/A	SC05 Input Validation

Root Cause: The contract tracks user liabilities in balances while allowing the owner to move ETH out without reducing those liabilities.

Business Logic Findings: The owner can effectively drain user funds. Withdrawals may fail even when balances show sufficient credit, creating a custodial rug-pull scenario.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.98 | Total_findings: 4
Critical: 1 | High: 2 | Medium: 0 | Low: 1
Precision_estimate: 0.96 | Coverage_estimate: 1.00 | Risk_score: 91/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - HOTELBOOKING

One-Page Visual Audit Report

Purpose: Hotel registry and room booking system using ETH payments.

Risk	Severity	SWC	OWASP
bookHotel() creates a booking but never stores it	Critical	N/A	SC02 Business Logic
Users pay ETH but receive no persistent reservation record	High	SWC-132	SC02 Financial Risks
Contract collects ETH with no owner withdrawal or refund path	Medium	SWC-132	SC02 Financial Risks
getCustomerBookings() performs unbounded loops over bookings	Medium	SWC-128	SC02 Gas/DoS

Root Cause: The core booking flow is incomplete: the Booking struct is created in memory but not pushed into hotel storage.

Business Logic Findings: Customers can pay for a booking that is never recorded. Funds can accumulate without operational settlement, refunds, or hotel payout logic.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.96 | Total_findings: 4

Critical: 1 | High: 1 | Medium: 2 | Low: 0

Precision_estimate: 0.94 | Coverage_estimate: 1.00 | Risk_score: 86/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - LOTERY

One-Page Visual Audit Report

Purpose: Ticket-based lottery with players, ticket accounting and winner selection.

Risk	Severity	SWC	OWASP
drawWinner() accepts caller-supplied randomness and is predictable/manipulable	Critical	SWC-120	SC02 Business Logic
Ticket weights are not represented in players array; odds are unfair	High	N/A	SC02 Business Logic
Winner selection uses contract balance as poolWeight, distorted by direct ETH transfers	Medium	N/A	SC02 Financial Risks
No payout, round finalization or owner/admin controls	Medium	N/A	SC02 Business Logic

Root Cause: Randomness and lottery accounting are not tied to a secure entropy source or a correct weighted ticket model.

Business Logic Findings: The lottery can return a manipulated winner and does not distribute funds. Extra ETH changes winner math without increasing player entries.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.95 | Total_findings: 4

Critical: 1 | High: 1 | Medium: 2 | Low: 0

Precision_estimate: 0.93 | Coverage_estimate: 1.00 | Risk_score: 88/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - NFTBAZAAR

One-Page Visual Audit Report

Purpose: Minimal NFT listing and purchase marketplace.

Risk	Severity	SWC	OWASP
Anyone can list any token ID without proving ownership	Critical	SWC-105	SC01 Access Control
seller and price are global, so one listing overwrites all token sales	High	N/A	SC02 Business Logic
buy() transfers payment to global seller and assigns arbitrary ownerOf[id]	High	SWC-105	SC02 Business Logic
No validation for zero price, listed state or existing token owner	Medium	N/A	SC05 Input Validation

Root Cause: Marketplace state is not modeled per token and lacks ownership authorization before listing or selling.

Business Logic Findings: A user can spoof listings, redirect payments, and overwrite ownership records without real NFT custody or ERC-721 transfer semantics.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.96 | Total_findings: 4

Critical: 1 | High: 2 | Medium: 1 | Low: 0

Precision_estimate: 0.94 | Coverage_estimate: 1.00 | Risk_score: 92/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - NFTMINTARENA

One-Page Visual Audit Report

Purpose: Paid NFT mint counter with configurable mint price and owner withdrawal.

Risk	Severity	SWC	OWASP
Minting only updates counters; no actual NFT ownership/token storage is created	High	N/A	SC02 Business Logic
Owner can set mintPrice to zero or arbitrary values	Medium	SWC-105	SC01 Access Control
Overpayments are accepted without refund logic	Medium	SWC-132	SC02 Financial Risks
Constructor lacks validation for zero maxSupply or inconsistent parameters	Low	N/A	SC05 Input Validation

Root Cause: The mint function emits events and updates counters but does not implement token ownership or ERC-721 mint semantics.

Business Logic Findings: Users may pay for a mint that only produces an event. Pricing is fully owner-controlled and excess payment stays trapped until owner withdrawal.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.93 | Total_findings: 4

Critical: 0 | High: 1 | Medium: 2 | Low: 1

Precision_estimate: 0.91 | Coverage_estimate: 1.00 | Risk_score: 68/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SAFEVAULT

One-Page Visual Audit Report

Purpose: ETH deposit vault with public balance tracking and withdrawal function.

Risk	Severity	SWC	OWASP
adminWithdraw() has no access control and lets anyone drain all ETH	Critical	SWC-105	SC01 Access Control
adminWithdraw() does not update user deposits, causing insolvency	High	SWC-132	SC02 Financial Risks
No user withdrawal function for recorded deposits	High	SWC-132	SC02 Business Logic
deposit() accepts zero-value deposits	Low	N/A	SC05 Input Validation

Root Cause: A privileged withdrawal path is implemented as a public function and is disconnected from deposit accounting.

Business Logic Findings: Any caller can remove all vault funds while user balances remain recorded. Depositors have no normal exit path.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.98 | Total_findings: 4
Critical: 1 | High: 2 | Medium: 0 | Low: 1
Precision_estimate: 0.96 | Coverage_estimate: 1.00 | Risk_score: 94/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SECUREVOTEMULTISIG

One-Page Visual Audit Report

Purpose: Multi-signature ETH execution contract based on owner approvals.

Risk	Severity	SWC	OWASP
execute() can be replayed because txHash is never marked executed	Critical	SWC-121	SC02 Business Logic
txHash is not bound on-chain to destination/value, enabling approval misuse	High	SWC-105	SC02 Business Logic
Constructor does not validate required threshold or duplicate/zero owners	High	N/A	SC05 Input Validation
approve() is public to non-owners, polluting approval state	Low	N/A	SC01 Access Control

Root Cause: The multisig approval model lacks transaction binding, execution state, and constructor invariant checks.

Business Logic Findings: A valid approval set can authorize repeated or different transfers if txHash governance is misused. Invalid thresholds can permanently break execution.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.95 | Total_findings: 4

Critical: 1 | High: 2 | Medium: 0 | Low: 1

Precision_estimate: 0.93 | Coverage_estimate: 1.00 | Risk_score: 89/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - SIMPLEAUCTION

One-Page Visual Audit Report

Purpose: Simple ETH auction with highest bid tracking and seller settlement.

Risk	Severity	SWC	OWASP
Previous highest bidders are overwritten without refunds or withdrawal credits	High	SWC-132	SC02 Financial Risks
endAuction() lacks require(!ended), allowing repeated settlement attempts	Medium	N/A	SC02 Business Logic
Only highestBid is paid to seller; excess/direct ETH can remain stuck	Medium	SWC-132	SC02 Financial Risks
No auction deadline or cancellation/refund lifecycle	Medium	N/A	SC02 Business Logic

Root Cause: Bid accounting stores only the latest bid and does not track refundable balances or a complete auction lifecycle.

Business Logic Findings: Outbid users lose access to their ETH. The seller can end the auction without time rules, and stray funds may remain trapped.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.94 | Total_findings: 4

Critical: 0 | High: 1 | Medium: 3 | Low: 0

Precision_estimate: 0.92 | Coverage_estimate: 1.00 | Risk_score: 74/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - TOKENORACLEDEX

One-Page Visual Audit Report

Purpose: Toy DEX that buys/sells internal balances using a mutable price variable.

Risk	Severity	SWC	OWASP
setPrice() is unrestricted; anyone can manipulate the oracle price	Critical	SWC-105	SC03 Oracle Manipulation
sell() makes external call before balance reduction	High	SWC-107	SC08 Reentrancy
price can be zero, causing sell() division-by-zero DoS	Medium	N/A	SC05 Input Validation
Internal balances are not backed by robust token or liquidity accounting	High	SWC-132	SC02 Financial Risks

Root Cause: The DEX trusts a public mutable price and performs ETH transfers before finalizing internal accounting.

Business Logic Findings: Attackers can set favorable prices, mint cheap internal balance, and attempt to drain ETH liquidity. Zero price can break redemptions.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.97 | Total_findings: 4
Critical: 1 | High: 2 | Medium: 1 | Low: 0
Precision_estimate: 0.95 | Coverage_estimate: 1.00 | Risk_score: 95/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - VAULTBANK

One-Page Visual Audit Report

Purpose: ETH vault with per-user balances and withdrawal function.

Risk	Severity	SWC	OWASP
withdraw() performs external call before decrementing balance	Critical	SWC-107	SC08 Reentrancy
No reentrancy guard on ETH withdrawals	High	SWC-107	SC08 Reentrancy
No owner/admin recovery or insolvency controls for unexpected ETH flows	Low	N/A	SC02 Financial Risks
deposit() accepts zero-value deposits	Low	N/A	SC05 Input Validation

Root Cause: The contract violates checks-effects-interactions by transferring ETH before updating the user's balance.

Business Logic Findings: A malicious receiver can reenter withdraw() while the balance is still unchanged and drain more ETH than intended if liquidity exists.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.97 | Total_findings: 4

Critical: 1 | High: 1 | Medium: 0 | Low: 2

Precision_estimate: 0.95 | Coverage_estimate: 1.00 | Risk_score: 90/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A

SMART CONTRACT SECURITY AUDIT - YIELDSTAKE

One-Page Visual Audit Report

Purpose: ETH staking balance tracker with rewards and withdrawals.

Risk	Severity	SWC	OWASP
reward() is unrestricted and lets any user mint stake credit	Critical	SWC-105	SC01 Access Control
Unbacked stake credits can drain ETH supplied by honest users	High	SWC-132	SC02 Financial Risks
No reward funding model or solvency invariant	High	N/A	SC02 Business Logic
No validation for zero deposits/rewards/withdrawals	Low	N/A	SC05 Input Validation

Root Cause: Reward issuance is public and not backed by funded yield or an authorized distributor role.

Business Logic Findings: An attacker can increase their stake for free and withdraw real ETH if the contract has liquidity, creating direct economic drain risk.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.97 | Total_findings: 4
Critical: 1 | High: 2 | Medium: 0 | Low: 1
Precision_estimate: 0.95 | Coverage_estimate: 1.00 | Risk_score: 93/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A